

御网智元方案设计文档

自主决策安全智能体的场景、流程与验证设计

版本日期：2026-09-03

御网智元方案设计文档

1. 设计原则

方案以“自主但受控、可解释且可复现、结果必须有证据”为三条主线。模型可以提出计划和候选行动，但不能自行扩大授权、绕过工具策略或宣布未经验证的结论。

2. 场景设计

场景	输入	主要工具	交付结果
CTF	题目文本、附件、本机靶场	文件、编码、哈希、Flag、localhost HTTP	线索链、候选结果、验证边界
应急响应	日志、流量、IOC 材料	IOC、时间线、PCAP、内容搜索	事件时间线、指标和处置建议
漏洞分析	源码、接口说明、响应材料	Web 证据、源码模式、HTTP 只读分析	风险判断、复现步骤和修复建议
静态逆向	字符串、二进制元数据	字符串、文件、静态元数据	结构线索和下一步分析计划

3. 自主决策设计

任务开始先生成 Task Brief，再生成计划。每个计划步骤必须有目标、理由、预期结果和验证方法。执行后只将结构化工具观察回传给模型；当工具失败、路径无进展、证据不足或出现新线索时，Agent 选择重规划、请求补充信息或安全结束。

4. 人机协同设计

用户可以在运行中追加指引、暂停、继续、停止或从检查点恢复。高风险动作需要审批；当前默认工具以离线分析和授权 localhost 只读探测为主。人机交接摘要会列出已验证结果、未验证候选、当前阻塞和建议接手动作。

5. 结果设计

模型输出只包含结果类型、标题、摘要、结构化数据、证据候选和置信度。服务端从当前 Run 绑定真实 ToolCall、Artifact 或 EvidenceRecord，并独立写入验证状态。报告、前端结果卡、评测和轨迹回放都读取同一份持久化结果。

6. 评测设计

本地评测将输入、允许工具、授权范围、预算、结构化结果 Schema 和私有 Judge 分离。评测检查工具是否调用、证据是否来自正确工具、是否越权、是否超预算以及结构化结果是否正确，不把非空文本或模型自述当作成绩。

7. 终审适配

主办方决赛平台开放后，优先替换 Provider 网关、目标授权适配器和外部结果提交接口；现有 Run、ToolSpec、Evidence、轨迹和评测接口保持不变。当前版本不虚构尚未提供的平台能力。